UNIVERSIDAD TÉCNICA NACIONAL

ISW-612 Administración de Sistemas Operativos de Red

Investigación Unidad III – Ambiente Windows

Acceso remoto seguro en Windows mediante RDP, WinRM y OpenSSH

Integrantes

Kevin Urbina

Profesor: Marcos Castro

III-26

26 de octubre de 2026

Resumen

Este trabajo evaluó la configuración de acceso remoto en Windows 11 mediante un auditor desarrollado en PowerShell, un contrato de datos JSON y una aplicación web local orientada a usuarios no técnicos. La solución revisa RDP y Network Level Authentication (NLA), WinRM, OpenSSH, perfiles del Firewall de Windows y la política de bloqueo de cuentas. El experimento se ejecutó en la máquina virtual W11-KUR. Se registró una línea base con umbral de bloqueo de 10 intentos, duración de 10 minutos y ventana de observación de 10 minutos. Posteriormente se aplicó un endurecimiento a 5 intentos y 15 minutos de bloqueo, manteniendo una ventana de 10 minutos. El puntaje académico de la aplicación mejoró de 88/100 a 100/100. Además, una cuenta local de prueba fue bloqueada tras cinco intentos fallidos y Windows registró el evento de seguridad 4740. Los resultados muestran que el endurecimiento aplicado mejoró los controles evaluados, aunque la hipótesis inicial solo fue apoyada parcialmente porque la línea base ya presentaba un puntaje superior al previsto.

Palabras clave: acceso remoto, RDP, WinRM, OpenSSH, PowerShell, bloqueo de cuentas, firewall, JSON, seguridad.

1. Introducción

El acceso remoto permite administrar equipos sin presencia física, pero también amplía la superficie de ataque cuando los servicios quedan expuestos, se utilizan mecanismos de autenticación débiles o no existen controles de bloqueo y auditoría. En Windows, RDP, WinRM y OpenSSH ofrecen distintos mecanismos para la administración remota. Microsoft indica que NLA agrega una capa adicional de seguridad a las conexiones de Escritorio remoto, mientras que WinRM puede utilizar HTTP o HTTPS y OpenSSH proporciona administración remota multiplataforma (Microsoft, s. f.-a; Microsoft, s. f.-b; Microsoft, s. f.-c).

El proyecto integra tres componentes: un script de PowerShell que audita el sistema, un archivo JSON que funciona como contrato de datos y una aplicación web que interpreta los resultados, calcula un puntaje de 0 a 100 y presenta recomendaciones. Esta arquitectura permite separar la recolección técnica de la visualización, facilitando la explicación de los hallazgos a una persona no especializada.

2. Planteamiento del problema

Los ataques de adivinación de credenciales se basan en múltiples intentos de autenticación. Windows permite configurar un umbral de bloqueo y una duración de bloqueo para limitar la cantidad de intentos fallidos antes de suspender temporalmente una cuenta. En equipos Windows 11 recientes, Microsoft documenta valores predeterminados de 10 intentos fallidos y 10 minutos de duración del bloqueo, valores que coinciden con la línea base observada en la máquina virtual de laboratorio (Microsoft, 2025).

A partir de este contexto se planteó la necesidad de medir de forma reproducible la configuración de acceso remoto, aplicar un endurecimiento controlado y comprobar si el cambio producía una mejora visible en el puntaje y un bloqueo efectivo ante intentos fallidos.

3. Pregunta de investigación e hipótesis

3.1 Pregunta de investigación

¿Qué configuraciones de RDP, WinRM y OpenSSH reducen el riesgo de fuerza bruta en Windows y cómo se mide esa reducción?

3.2 Hipótesis

La hipótesis inicial planteó que un sistema Windows con configuración predeterminada obtendría un puntaje inferior a 50/100 y que, después de aplicar endurecimiento mediante NLA, políticas más estrictas de bloqueo de cuentas y controles de Firewall de Windows, el puntaje superaría 80/100 y los intentos masivos de acceso no autorizado serían detectados y bloqueados.

Resultado de la hipótesis: La hipótesis fue apoyada parcialmente. La mejora posterior al endurecimiento sí se observó y el puntaje final superó 80/100; sin embargo, la línea base fue 88/100, por lo que no se confirmó la predicción de un valor inicial inferior a 50/100.

4. Objetivos

4.1 Objetivo general

Evaluar la configuración de acceso remoto seguro en Windows mediante un auditor en PowerShell y una aplicación web que permita medir el estado de los controles y comparar el efecto de un endurecimiento de seguridad.

4.2 Objetivos específicos

- Auditar RDP, NLA, WinRM, OpenSSH, Firewall de Windows y la política de bloqueo de cuentas.
- Exportar los resultados a un archivo JSON reutilizable por una aplicación web local.
- Implementar un puntaje académico de seguridad y generar recomendaciones de remediación.
- Comparar el estado antes y después del endurecimiento de la política de bloqueo.
- Verificar experimentalmente el bloqueo de una cuenta de prueba y su registro en el evento 4740 de Windows.

5. Marco teórico

5.1 RDP y NLA

Remote Desktop Protocol (RDP) permite establecer sesiones remotas en Windows. NLA exige autenticación antes de completar la sesión remota y Microsoft la describe como una capa adicional de seguridad para las conexiones de Escritorio remoto (Microsoft, s. f.-a). En el laboratorio, RDP permaneció deshabilitado, pero el auditor comprobó que NLA estaba habilitado y que el puerto configurado era 3389.

5.2 WinRM

Windows Remote Management (WinRM) implementa WS-Management para administración remota. Microsoft documenta los puertos 5985 para HTTP y 5986 para HTTPS. El uso de HTTPS permite establecer el transporte mediante TLS y es una alternativa relevante cuando se requiere administración remota con mayor protección de canal (Microsoft, s. f.-b; Microsoft, s. f.-d). En la VM del proyecto WinRM se mantuvo deshabilitado porque no era necesario para la prueba experimental.

5.3 OpenSSH

OpenSSH proporciona herramientas SSH para administración remota multiplataforma en Windows. Microsoft documenta autenticación por contraseña y por clave pública. En el entorno evaluado, el servicio OpenSSH estaba deshabilitado, lo que evita exposición innecesaria cuando el servicio no se utiliza (Microsoft, s. f.-c).

5.4 Bloqueo de cuentas y auditoría

La política de bloqueo de cuentas determina cuántos intentos fallidos pueden realizarse antes de bloquear una cuenta y durante cuánto tiempo permanece bloqueada. Microsoft advierte que estos valores deben equilibrar la mitigación de fuerza bruta con el riesgo de bloqueo

accidental o denegación de servicio. El evento 4740 registra el bloqueo de una cuenta de usuario y puede utilizarse como evidencia de auditoría (Microsoft, s. f.-e; Microsoft, s. f.-f).

6. Metodología

6.1 Entorno de laboratorio

Las pruebas se realizaron en una máquina virtual Windows 11 denominada W11-KUR, dentro de un entorno de laboratorio propio. Se utilizó una cuenta local de prueba llamada pruebaISW612 para evitar afectar la cuenta administrativa principal. Las pruebas no se ejecutaron contra sistemas externos ni se utilizaron credenciales reales de terceros.

6.2 Arquitectura de la solución

El flujo de trabajo implementado fue: configuración del sistema → auditor PowerShell → archivo JSON → aplicación web → puntaje y recomendaciones. El script consulta el Registro, servicios, perfiles del Firewall y la política de bloqueo; luego serializa los resultados a JSON. La aplicación web procesa el archivo localmente mediante JavaScript, sin servidor ni API externa.



Figura 1. Arquitectura implementada para la auditoría y visualización de resultados.

6.3 Procedimiento experimental

1. Ejecutar el auditor en W11-KUR y guardar el resultado como antes.json.
2. Registrar la línea base de la política: umbral 10, duración 10 minutos y ventana 10 minutos.
3. Aplicar un endurecimiento de la política: umbral 5 y duración 15 minutos; la ventana se mantuvo en 10 minutos.
4. Ejecutar nuevamente el auditor y guardar el resultado como despues.json.
5. Cargar ambos archivos en la aplicación web y comparar el puntaje y las recomendaciones.
6. Crear la cuenta local pruebaISW612 y realizar cinco intentos fallidos de inicio de sesión de forma controlada.
7. Verificar el bloqueo de la cuenta mediante Win32_UserAccount y confirmar el evento 4740 en el registro de seguridad.

7. Implementación

7.1 Script PowerShell

El archivo script/auditor-acceso-remoto.ps1 obtiene el nombre del equipo y la fecha de auditoría, determina si RDP está habilitado, consulta el puerto RDP y el estado de NLA, revisa el estado de WinRM y OpenSSH, obtiene los perfiles Domain, Private y Public del Firewall de Windows, recopila reglas asociadas a servicios remotos y procesa la salida de net accounts para extraer la política de bloqueo. Finalmente genera datos/ejemplo.json.

7.2 Contrato JSON

El JSON contiene los campos equipo, fecha, servicios, firewall y politica_bloqueo. Cada servicio incorpora nombre, estado, puerto, autenticación y reglas de firewall. Esta estructura permite que la aplicación web no dependa de PowerShell durante la visualización y facilita conservar estados históricos como antes.json y despues.json.

7.3 Aplicación web y puntaje

La aplicación web permite seleccionar un archivo JSON desde el navegador, muestra el equipo auditado, los servicios, la política de bloqueo y el estado del Firewall, y calcula un puntaje interno de 0 a 100. El puntaje es un modelo académico del proyecto y no una escala oficial de Microsoft.

Control	Puntaje máximo
RDP + NLA	25
Firewall de Windows	25
Política de bloqueo	30
WinRM	10
OpenSSH	10
Total	**100**

Tabla 1. Distribución del puntaje académico utilizado por la aplicación web.

Dentro de los 30 puntos de la política de bloqueo, 15 corresponden al umbral, 10 a la duración y 5 a la ventana de observación. Con un umbral de 10 y una duración de 10 minutos, la

línea base obtiene 18 de esos 30 puntos. Con un umbral de 5 y una duración de 15 minutos, la política obtiene los 30 puntos completos.

8. Resultados

8.1 Estado inicial

La auditoría inicial de W11-KUR detectó RDP deshabilitado, NLA habilitado, WinRM deshabilitado, OpenSSH deshabilitado y los tres perfiles del Firewall de Windows habilitados. La política de bloqueo era de 10 intentos, 10 minutos de duración y 10 minutos de ventana. La aplicación asignó 88/100 y recomendó reducir el umbral a 5 intentos y aumentar la duración a 15 minutos.

8.2 Estado posterior al endurecimiento

Después del cambio, el umbral se redujo a 5 intentos y la duración se incrementó a 15 minutos; la ventana permaneció en 10 minutos. Los demás controles evaluados se mantuvieron. La aplicación asignó 100/100 y no generó recomendaciones críticas.

Indicador	Antes	Después
Umbral de bloqueo	10	5
Duración del bloqueo	10 min	15 min
Ventana de observación	10 min	10 min
Puntaje de seguridad	88/100	100/100

Tabla 2. Comparación de la política y el puntaje antes y después del endurecimiento.

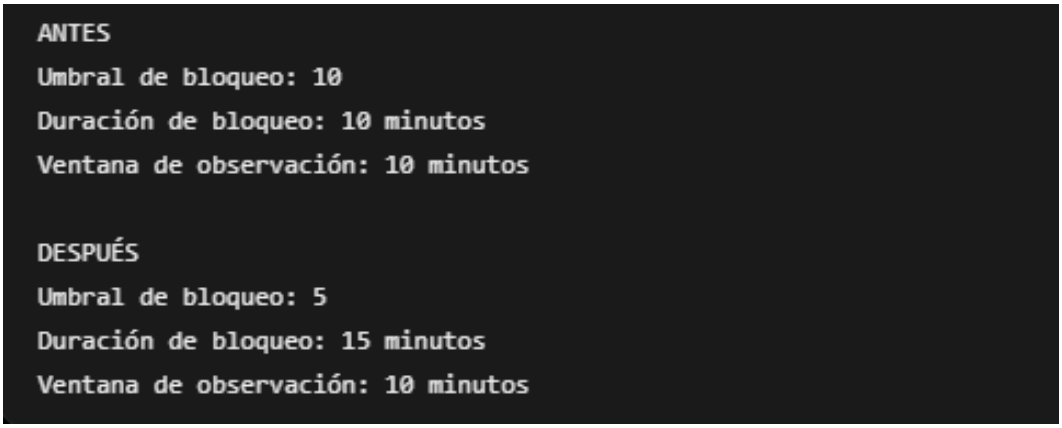


Figura 2. Evidencia de la comparación de la política antes y después del endurecimiento.

8.3 Prueba controlada de bloqueo

Para validar el funcionamiento de la política se creó la cuenta local pruebaISW612 y se realizaron cinco intentos fallidos de inicio de sesión. La consulta posterior mostró Lockout = True, confirmando que la cuenta quedó bloqueada al alcanzar el umbral configurado. El registro de seguridad de Windows mostró el evento 4740, asociado al bloqueo de una cuenta de usuario (Microsoft, s. f.-f).

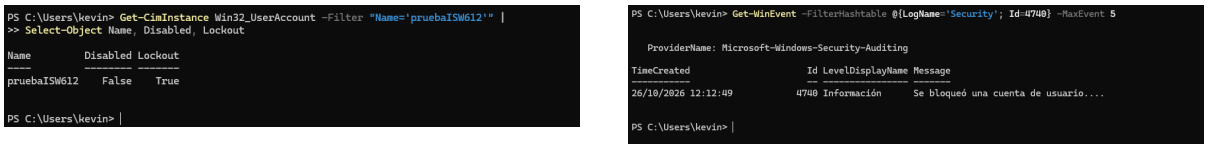


Figura 3. Confirmación del estado Lockout=True y registro del evento 4740.

9. Discusión

Los resultados confirman que la solución permite medir cambios de configuración y presentar el efecto del endurecimiento de manera comprensible. La mejora de 88/100 a 100/100 provino exclusivamente de la política de bloqueo, ya que RDP/NLA, Firewall, WinRM y OpenSSH no cambiaron entre ambas mediciones. Por tanto, el aumento del puntaje no debe interpretarse como una medición absoluta de riesgo, sino como la respuesta del modelo académico a los controles definidos.

La línea base de 10 intentos y 10 minutos no era una configuración insegura en sentido absoluto. De hecho, Microsoft documenta 10 intentos y 10 minutos como valores predeterminados en equipos Windows 11 recientes y sus guías advierten que reducir demasiado el umbral puede facilitar ataques de denegación de servicio mediante bloqueos intencionales (Microsoft, 2025; Microsoft, s. f.-e). En este proyecto se utilizó un umbral de 5 para demostrar experimentalmente una política más estricta y hacer observable el efecto del endurecimiento dentro del laboratorio.

La hipótesis se confirmó solo parcialmente. El sistema sí mejoró después del endurecimiento y superó 80/100, pero la predicción de una línea base inferior a 50/100 no se cumplió. Este hallazgo es útil porque muestra que una hipótesis puede ser revisada a partir de evidencia experimental y que el puntaje debe interpretarse en función de los criterios definidos por la aplicación.

10. Limitaciones

- La simulación de intentos fallidos se realizó de forma interactiva sobre una cuenta local de prueba dentro de W11-KUR; no se automatizó desde una segunda VM.
- La versión entregada utiliza el mecanismo nativo de bloqueo de cuentas de Windows; no se implementó un bloqueo dinámico temporal por dirección IP mediante una regla nueva de Firewall.
- RDP, WinRM y OpenSSH permanecieron deshabilitados durante el experimento, por lo que no se realizó una comparación funcional entre los tres protocolos.
- El puntaje 0-100 es una métrica académica definida por el proyecto y no sustituye una evaluación formal de riesgo o una línea base oficial de Microsoft.
- VPN y MFA se trataron únicamente a nivel conceptual, de acuerdo con el alcance del proyecto.

11. Conclusiones

- Se implementó una arquitectura completa de auditoría, serialización y visualización basada en PowerShell, JSON y una aplicación web local.
- El auditor permitió comprobar RDP/NLA, WinRM, OpenSSH, Firewall de Windows y la política de bloqueo en una VM controlada.

- El endurecimiento de la política de bloqueo cambió el umbral de 10 a 5 intentos y la duración de 10 a 15 minutos, elevando el puntaje académico de 88/100 a 100/100.
- La cuenta pruebaISW612 quedó bloqueada tras alcanzar el umbral y el evento 4740 confirmó el bloqueo en el registro de seguridad de Windows.
- La hipótesis inicial fue apoyada parcialmente: se observó mejora y el puntaje final superó 80/100, pero el puntaje inicial no fue inferior a 50/100.

12. Recomendaciones

- Mantener deshabilitados los servicios de acceso remoto que no sean necesarios.
- Cuando RDP sea requerido, conservar NLA y restringir el acceso mediante reglas de Firewall, VPN o controles equivalentes.
- Para WinRM, preferir HTTPS cuando el escenario lo requiera y revisar cuidadosamente TrustedHosts y autenticación.
- Para OpenSSH, considerar autenticación con clave pública y limitar el acceso a las cuentas que realmente lo necesiten.
- En una versión futura, incorporar el bloqueo temporal por IP solicitado en el enunciado y automatizar la simulación desde una segunda VM para medir el tiempo de detección y bloqueo.

Referencias

Microsoft. (2025). Windows 11 security book: Advanced credential protection. Microsoft Learn. https://learn.microsoft.com/windows/security/book/identity-protection-advanced-credential-protection

Microsoft. (s. f.-a). Enable Remote Desktop on your PC. Microsoft Learn. https://learn.microsoft.com/windows-server/remote/remote-desktop-services/remotepc/remote-desktop-allow-access

Microsoft. (s. f.-b). How to configure WinRM for HTTPS. Microsoft Learn. https://learn.microsoft.com/en-us/troubleshoot/windows-client/system-management-components/configure-winrm-for-https

Microsoft. (s. f.-c). OpenSSH for Windows overview. Microsoft Learn. https://learn.microsoft.com/en-us/windows-server/administration/openssh/openssh-overview

Microsoft. (s. f.-d). Security considerations for PowerShell Remoting using WinRM. Microsoft Learn. https://learn.microsoft.com/powershell/scripting/security/remoting/winrm-security

Microsoft. (s. f.-e). Account lockout threshold. Microsoft Learn. https://learn.microsoft.com/windows/security/threat-protection/security-policy-settings/account-lockout-threshold

Microsoft. (s. f.-f). 4740(S): A user account was locked out. Microsoft Learn. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4740

Apéndice A. Evidencia de la aplicación web



Figura A1. Puntaje antes del endurecimiento: 88/100.

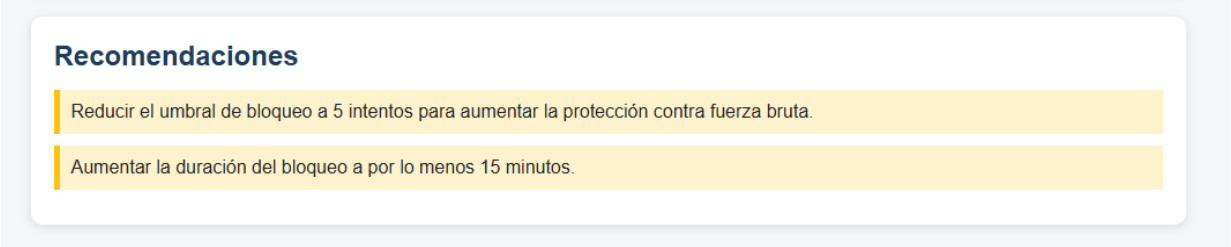


Figura A2. Recomendaciones generadas para la línea base.



Figura A3. Puntaje después del endurecimiento: 100/100.

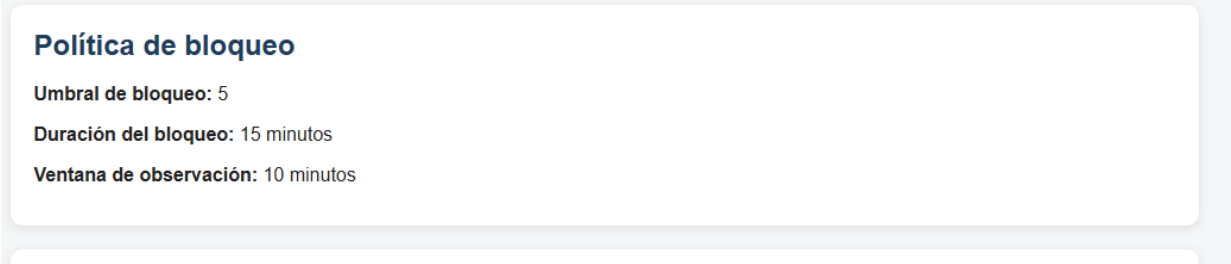


Figura A4. Política de bloqueo después del endurecimiento.

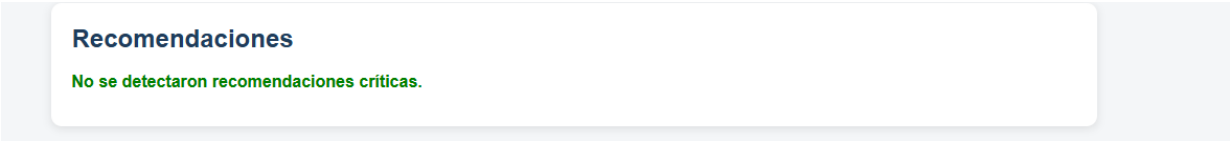


Figura A5. Estado final sin recomendaciones críticas.

Apéndice B. Evidencia del bloqueo

```
PS C:\Users\kevin> Get-CimInstance Win32_UserAccount -Filter "Name='pruebaISW612'" |
>> Select-Object Name, Disabled, Lockout

Name         Disabled Lockout
----         -------- -------
pruebaISW612    False    True


PS C:\Users\kevin>
```

Figura B1. La cuenta pruebaISW612 aparece con Lockout=True.

```
PS C:\Users\kevin> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4740} -MaxEvent 5


   ProviderName: Microsoft-Windows-Security-Auditing

TimeCreated                     Id LevelDisplayName Message
-----------                     -- ---------------- -------
26/10/2026 12:12:49           4740 Información      Se bloqueó una cuenta de usuario....


PS C:\Users\kevin>
```

Figura B2. Evento 4740 registrado por Windows Security Auditing.